

Informe Profesional de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información

Licenciatura en Sistemas de Información — Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Contratista: Facundo San Martin — DNI 46396821

Username TryHackMe: cundosanmartin84

Email: cundosanmartin84@gmail.com

Branch GitHub: SanMartin-Facundo

8 de octubre de 2026

Declaración Ética

Todas las actividades documentadas en este informe fueron realizadas dentro del alcance autorizado por la cátedra, exclusivamente sobre los entornos de laboratorio de la plataforma TryHackMe. No se aplicó ninguna técnica contra sistemas reales. El presente trabajo constituye una auditoría académica sin fines de lucro.

Índice

1. Contexto de la Contratación	3
2. Pre-pentesting	3
2.1. Datos generales	3
2.2. Alcance del trabajo	3
2.3. Reglas de Enfrentamiento (ROE)	4
2.4. Autorización	4
2.5. Metodología utilizada	4
3. Hallazgos por Fase	5
3.1. Fase 1 — Reconocimiento	5
3.2. Fase 2 — Escaneo	5
3.3. Fase 3 — Explotación	6
3.4. Fase 4 — Post-Explotación	8
4. Resumen Ejecutivo de Hallazgos	9
5. Post-pentesting: Recomendaciones	9

6. Protocolo de Contingencia	10
7. Anexos	10
7.1. Anexo A — Bitácora de comandos	10
7.2. Anexo B — Capturas de pantalla	10
7.3. Anexo C — Hashes SHA-256 de flags	11
7.4. Anexo D — Declaración ética firmada	11
8. Rúbrica de Evaluación (A08)	11
9. Fuentes y bibliografía	11

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Facundo San Martin (estudiante de Seguridad Aplicada a Sistemas de Información).

Objeto del contrato: La compañía INSECUR S.A. contrata servicios profesionales de Hacking Ético para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma TryHackMe.

Entregable: Informe profesional de pentesting + protocolo de contingencia.

Modalidad: Individual.

Repositorio: https://github.com/UCHSeguridad2026/TP_THM.git

2. Pre-pentesting

2.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista	Facundo San Martin
DNI	46396821
Username TryHackMe	cundosanmartin84
Email institucional	cundosanmartin84@gmail.com
Sala de elección (Nivel 2)	Vulnversity
Branch en GitHub	SanMartin-Facundo
Fecha de inicio	07/10/2026
Fecha de cierre	08/10/2026

2.2. Alcance del trabajo

Alcance

El presente pentesting se realizó exclusivamente sobre **tres salas de laboratorio de TryHackMe**:

- **Pentesting Fundamentals** — sala teórica introductoria.
- **Basic Pentesting** — máquina Linux con vulnerabilidades de enumeración, fuerza bruta SSH y escalada.
- **Vulnversity** — máquina Linux con vulnerabilidades en upload de archivos y SUID mal configurado.

Quedan excluidos: cualquier sistema productivo real, redes corporativas, infraestructura de la facultad y equipos personales ajenos al laboratorio.

2.3. Reglas de Enfrentamiento (ROE)

ROE

- **Horario:** sesiones de trabajo de 2–4 horas, sin afectar servicios productivos.
- **Técnicas permitidas:** nmap, gobuster, enum4linux, hydra, john the ripper, metasploit (solo si la sala lo requiere), openssl, steghide.
- **Técnicas prohibidas:** ataques de denegación de servicio, explotación fuera de la IP asignada por THM, cualquier técnica contra sistemas reales.
- **Notificación:** ante cualquier comportamiento anómalo, se documenta y se detiene la sesión.
- **Tráfico:** limitado a la VPN de TryHackMe (tun0).

2.4. Autorización

Autorización expresa

El alumno declara contar con autorización expresa de la cátedra “Seguridad Aplicada a Sistemas de Información” (Facultad de Informática y Diseño, UCH) para trabajar sobre los entornos controlados de TryHackMe. Toda actividad se realizó en un entorno *sandbox* y con fines exclusivamente académicos.

2.5. Metodología utilizada

Metodología

Se adoptó el marco **NIST SP 800-115** (Technical Guide to Information Security Testing and Assessment), complementado con las fases clásicas de **PTES** (Penetration Testing Execution Standard):

1. Pre-engagement (alcance y ROE)
2. Information Gathering (OSINT)
3. Scanning & Enumeration
4. Exploitation
5. Post-Exploitation
6. Reporting

Se eligió NIST SP 800-115 por ser un estándar reconocido internacionalmente, citado en la bibliografía de la cátedra, y por su enfoque en documentación formal del proceso.

3. Hallazgos por Fase

A continuación se documentan los hallazgos relevantes obtenidos durante el pentesting, organizados por fase metodológica.

3.1. Fase 1 — Reconocimiento

Campo	Valor
ID del hallazgo	H-01
Fase	Reconocimiento
Descripción	Información pública expuesta en LinkedIn de un empleado de ACME (sala Pentesting Fundamentals)
Componente afectado	Recursos Humanos / Redes sociales corporativas
Categoría (OWASP / CWE)	CWE-200: Exposure of Sensitive Information
CVE (si aplica)	N/A
CVSS estimado	Bajo
Evidencia	Captura <code>reconocimiento_H-01.png</code>
Herramienta utilizada	Navegador web (OSINT manual)
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Política de redes sociales + capacitación anti-phishing
Riesgo residual tras aplicar	Bajo

3.2. Fase 2 — Escaneo

Campo	Valor
ID del hallazgo	H-02
Fase	Escaneo
Descripción	Enumeración de servicios en Vulniversity: FTP (21), SSH (22), SMB (139/445), Squid (3128), Apache (3333)
Componente afectado	Servidor VulnUniversity
Categoría (OWASP / CWE)	CWE-200: Information Exposure Through Service Enumeration
CVSS estimado	Medio
Evidencia	Captura <code>escaneo_H-02.png</code>
Herramienta utilizada	Nmap 7.99 (<code>nmap -sV -sC</code>)
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Firewall con filtrado por puerto, cierre de servicios innecesarios

Riesgo residual Bajo
tras aplicar

Campo	Valor
ID del hallazgo	H-03
Fase	Escaneo
Descripción	Directorio <code>/internal/</code> con formulario de upload sin autenticación en Vulniversity
Componente afectado	Aplicación web VulnUniversity
Categoría (OWASP / CWE)	OWASP A05:2021 — Security Misconfiguration
CVSS estimado	Alto
Evidencia	Captura <code>escaneo_H-03.png</code>
Herramienta utilizada	Gobuster 3.8.2
Impacto en la Tríada CIA	Confidencialidad + Integridad
Salvaguarda propuesta	Autenticación en panel admin, restricción de extensiones, validación server-side
Riesgo residual tras aplicar	Bajo

3.3. Fase 3 — Explotación

Campo	Valor
ID del hallazgo	H-04
Fase	Explotación
Descripción	Upload de webshell <code>.phtml</code> en Vulniversity (bypass del filtro de extensiones)
Componente afectado	Servidor Apache (puerto 3333)
Categoría (OWASP / CWE)	OWASP A03:2021 — Injection / Upload CWE-434: Unrestricted
CVSS estimado	Crítico
Evidencia	Captura <code>explotacion_H-04.png</code>
Herramienta utilizada	Reverse shell PHP de PentestMonkey + netcat
Impacto en la Tríada CIA	Confidencialidad + Integridad + Disponibilidad
Salvaguarda propuesta	Whitelist de extensiones, validación MIME, separación de uploads del webroot
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-05
Fase	Explotación
Descripción	Enumeración SMB en Basic Pentesting: usuarios <code>jan</code> , <code>kay</code> , <code>ubuntu</code>
Componente afectado	Servidor Samba (139/445)
Categoría (OWASP / CWE)	CWE-200: Information Exposure
CVSS estimado	Medio
Evidencia	Captura <code>explotacion_H-05.png</code>
Herramienta utilizada	<code>enum4linux</code>
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Restringir acceso anónimo a SMB, deshabilitar SMBv1
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-06
Fase	Explotación
Descripción	Fuerza bruta exitosa sobre SSH de Basic Pentesting (usuario <code>jan</code> / password <code>armando</code>)
Componente afectado	Servicio SSH (puerto 22)
Categoría (OWASP / CWE)	CWE-521: Weak Password Requirements
CVSS estimado	Alto
Evidencia	Captura <code>explotacion_H-06.png</code>
Herramienta utilizada	<code>Hydra 9.7</code>
Impacto en la Tríada CIA	Confidencialidad + Integridad
Salvaguarda propuesta	Política de contraseñas robusta, fail2ban, autenticación por clave pública, MFA
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-07
Fase	Explotación
Descripción	Clave privada SSH de <code>kay</code> accesible por <code>jan</code> y crackeable con John (passphrase <code>beeswax</code>)

Componente afectado	Directorio <code>/home/kay/.ssh/</code>
Categoría (OWASP / CWE)	CWE-522: Insufficiently Protected Credentials
CVSS estimado	Alto
Evidencia	Captura <code>explotacion_H-07.png</code>
Herramienta utilizada	<code>ssh2john</code> + John the Ripper
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	Permisos 700 en <code>.ssh/</code> , passphrase robusta, rotación de claves
Riesgo residual tras aplicar	Bajo

3.4. Fase 4 — Post-Explotación

Campo	Valor
ID del hallazgo	H-08
Fase	Post-Explotación
Descripción	SUID mal configurado en <code>/bin/systemctl</code> permite escalar de <code>www-data</code> a <code>root</code>
Componente afectado	Sistema operativo Ubuntu
Categoría (OWASP / CWE)	CWE-269: Improper Privilege Management
CVSS estimado	Crítico
Evidencia	Captura <code>post_H-08.png</code>
Herramienta utilizada	<code>systemctl</code> + servicio malicioso
Impacto en la Tríada CIA	Confidencialidad + Integridad + Disponibilidad
Salvaguarda propuesta	Auditar binarios SUID periódicamente, principio de menor privilegio
Riesgo residual tras aplicar	Bajo

Campo	Valor
ID del hallazgo	H-09
Fase	Post-Explotación
Descripción	Archivo <code>pass.bak</code> con contraseña final accesible desde <code>kay</code>
Componente afectado	Home de <code>kay</code>
Categoría (OWASP / CWE)	CWE-256: Plaintext Storage of Password

CVSS estimado	Alto
Evidencia	Captura post_H-09.png
Herramienta utilizada	cat
Impacto en la Tríada CIA	Confidencialidad
Salvaguarda propuesta	No almacenar contraseñas en texto plano, usar gestores de secretos
Riesgo residual tras aplicar	Bajo

4. Resumen Ejecutivo de Hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-04, H-08
Alto	3	H-03, H-06, H-07, H-09
Medio	2	H-02, H-05
Bajo	1	H-01
Total	9	

5. Post-pentesting: Recomendaciones

Recomendaciones técnicas

1. **Crítico (24–48 hs):** Auditar y remover binarios SUID innecesarios (`/bin/systemctl`). Aplicar whitelist de extensiones en formularios de upload.
2. **Alto (1–2 semanas):** Implementar política de contraseñas robusta (mín. 12 caracteres, complejidad, rotación). Configurar fail2ban en SSH. Restringir acceso anónimo a SMB. Cifrar claves privadas con passphrase robusta.
3. **Medio (1–3 meses):** Separar uploads del webroot. Implementar MFA en accesos administrativos. Monitorización con SIEM.
4. **Bajo (continuo):** Capacitación anti-phishing. Revisión de exposición pública en redes sociales.

Recomendaciones administrativas

1. Establecer políticas formales de gestión de credenciales y secretos.
2. Capacitar al personal en seguridad de la información (phishing, contraseñas, redes sociales).
3. Realizar auditorías de seguridad periódicas (semestrales o anuales).
4. Designar un responsable de seguridad (CISO) y definir roles.
5. Mantener inventario actualizado de activos y servicios expuestos.

6. Protocolo de Contingencia

Escenario de falla

Durante un pentesting autorizado, un exploit podría provocar la caída inesperada del servidor web (por ejemplo, un payload mal calibrado que consuma todos los recursos o un servicio que no reinicie tras la explotación). En producción, esto afectaría la disponibilidad del portal de clientes de INSECUR S.A.

Impacto sobre la continuidad del negocio

- **Procesos afectados:** portal de clientes, autenticación de usuarios, facturación online.
- **Tiempo estimado de interrupción:** 1–4 horas.
- **Impacto económico estimado:** pérdida de transacciones durante la ventana de caída.
- **Impacto reputacional:** potencial insatisfacción de clientes si se hace público.

Plan de respuesta

1. **Activación:** monitorización con Nagios/Zabbix detecta caída del servicio y dispara alerta al equipo de guardia.
2. **Contención (primeros 15 min):** aislar el servidor afectado de la red, preservar evidencia forense, notificar al responsable de seguridad.
3. **Recuperación:** restaurar desde snapshot/backup más reciente (máx. 24 hs de antigüedad). Validar integridad y disponibilidad antes de reexponer.
4. **Comunicación:** informar a dirección, clientes afectados y, si aplica, autoridades (Ley 25.326 de Protección de Datos).
5. **Post-mortem:** documentar causa raíz, impacto, acciones correctivas y lecciones aprendidas en un informe a los 5 días.

RTO y RPO estimados

RTO (Recovery Time Objective): **4 horas**
RPO (Recovery Point Objective): **24 horas**

7. Anexos

7.1. Anexo A — Bitácora de comandos

El archivo `bitacora/clase_09_20261007.txt` contiene el historial depurado de comandos utilizados, con secretos filtrados mediante `sed`.

7.2. Anexo B — Capturas de pantalla

Las capturas se encuentran organizadas en `evidencias/` con subcarpetas por fase:

- `evidencias/reconocimiento/` — 4 capturas
- `evidencias/escaneo/` — 9 capturas

- evidencias/explotacion/ — 12 capturas
- evidencias/post/ — 8 capturas

7.3. Anexo C — Hashes SHA-256 de flags

```

1 # Comando: echo -n "FLAG" | sha256sum
2
3 # User flag Vulniversity (H-04)
4 Original: 8bd7992fbe8a6ad22a63361004cfcedb
5 SHA256:   d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
6
7 # Root flag Vulniversity (H-08)
8 Original: a58ff8579f0a9270368d33a9966c7fd5
9 SHA256:   cfbc740435ad600303040e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

```

7.4. Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Facundo San Martin

Fecha

8. Rúbrica de Evaluación (A08)

Criterio	Peso	Cumplimiento
A. Recopilación de información	10 %	Fuentes citadas y documentadas
B. Elaboración de documentos	25 %	Formato completo de la plantilla
C. Elaboración de presentaciones	10 %	Argumentación del caso y soluciones
D. Integración de soluciones	25 %	Parches y medidas integradas
E. Selección de herramientas	20 %	Herramientas justificadas
F. Consciencia de buenas prácticas	10 %	Declaración ética + bitácora filtrada

9. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*. <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. *Basic Pentesting*. <https://tryhackme.com/room/basicpentestingjt>
- TryHackMe. *Vulniversity*. <https://tryhackme.com/room/vulniversity>
- OWASP Foundation. *Web Security Testing Guide (WSTG)*. <https://owasp.org/www-project-web-security->
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide*.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*.